

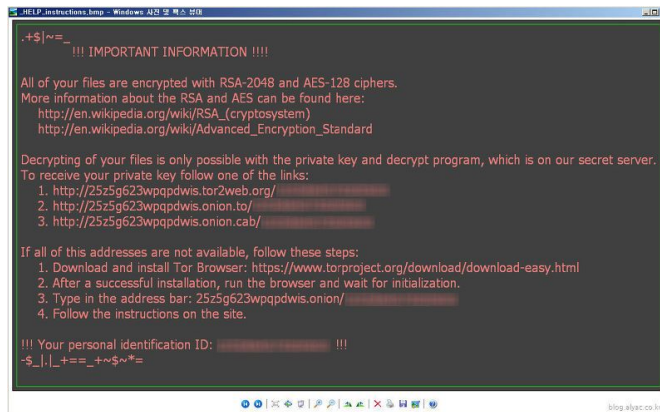
랜섬웨어란

1. 개요

랜섬웨어(Ransomware)는 '몸값(Ransom)'과 '소프트웨어(Software)'의 합성어로, 사용자 컴퓨터 시스템의 파일이나 데이터를 암호화하여 사용 불가능하게 만든 뒤, 이를 풀어주는 대가로 금전을 요구하는 악성코드입니다.

개인을 넘어 기업, 병원, 국가 기반 시설까지 공격 대상으로 삼으며 그 피해 규모와 심각성이 날로 커지고 있습니다.

대표적인 예시로는 WannaCry, Locky, Petya 등이 있습니다.



WannaCry 랜섬웨어 감염 영상

다음 영상은 랜섬웨어가 컴퓨터를 점령하는 과정을 보여줍니다.

WannaCry Ransomware Attack: Impact (Global)



Sectors Affected



Health Services, Automobile Manufacturers,
Telecom Services Providers, Banks, Logistics,
OEMs, Railways...

Petya 랜섬웨어 감염 및 복구 영상

다음 영상은 랜섬웨어가 컴퓨터 부팅 화면을 점령하는 과정을 보여줍니다.

화면 색상이 **빨강, 초록, 노란색**으로 **강하게** 변하니 눈이 민감한 분들은 **시청에 주의**하세요

빨강 맛



초록 맛



노랑 맛



PRESS ANY KEY

2. 랜섬웨어 관련 주요 통계 지표

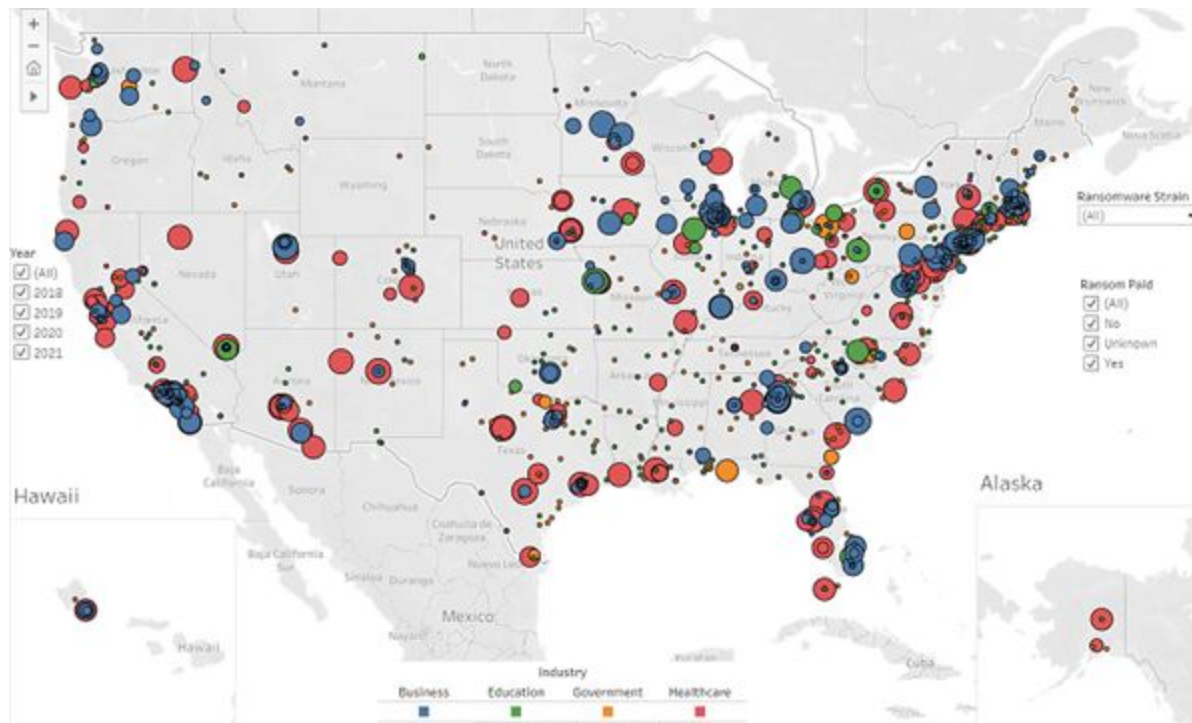
- 2024년 랜섬웨어 관련 주요 통계 자료

- ❖ 2024년 전 세계 금융 기관의 약 **65%**가 랜섬웨어 공격을 경험했다고 보고했습니다. (Statista)
- ❖ 2024년 상반기 동안 활동 중인 랜섬웨어 그룹의 수가 **56%** 증가했습니다. (Searchlight Cyber)
- ❖ 사이버 범죄로 인한 연평균 피해 비용은 **2027년까지 23조 달러**를 초과할 것으로 예상됩니다. (미국 국무부)
- ❖ 전 세계 조직의 사이버 보안 전문가를 대상으로 한 조사에서 **32%**의 기업이 취약점이 악용되어 랜섬웨어 공격을 당했다고 응답했습니다. (Statista)
- ❖ 지난해 새롭게 발견된 보안 취약점이 **30,000건**을 넘어섰습니다. (TechTarget)
- ❖ 2024년 1월과 2월 사이, 전 세계 조직의 **59%**가 랜섬웨어 공격을 경험했습니다. (Statista)
- ❖ 랜섬웨어 피해자의 평균 **43%**는 공격으로 인해 손상된 데이터를 영구적으로 복구하지 못했습니다. (SCWorld)
- ❖ 자격 증명 탈취는 랜섬웨어 공격의 두 번째 주요 원인이었으며, 악성 이메일이 그 뒤를 이었습니다. (Statista)

** 관련 자료 URL :

<https://www.sangfor.com/kr/blog/cybersecurity/ransomware-attacks-2024-top-ransomware-headlines>

미국 내 랜섬웨어 피해 사례 (2018 ~ 2021)



3. 랜섬 웨어 유형 및 사고 사례

3.1 암호화 랜섬웨어 (Crypto Ransomware)

가장 대표적인 유형으로, 시스템의 파일을 직접 암호화하여 사용을 막습니다.

3.1.1 2024년 2월, 미국, '체인지 헬스케어'사 피해 사례

2024년 2월, 미국 최대 의료 결제 시스템 운영사인 '체인지 헬스케어'가 랜섬웨어 공격을 받아 수 주간 운영이 마비되는 사상 초유의 사태가 발생했습니다. '**ALPHV/블랙캣 (BlackCat)**' 랜섬웨어 조직이 주도한 이 공격으로 미국 전역의 병원과 약국에서 처방전 처리, 보험 청구, 결제 시스템이 중단되어 환자 진료에 막대한 차질을 빚었습니다. 공격자들은 시스템을 암호화했을 뿐만 아니라, 수백만 명의 환자 정보가 포함된 **6TB** 규모의 데이터를 탈취했다고 주장했습니다. 결국 모기업인 유나이티드헬스 그룹은 해커들에게 **2,200만 달러(약 300억 원)**의 몸값을 지불한 것으로 알려졌습니다. 이 사건은 단일 계정의 보안 실패가 국가 보건 시스템 전체를 마비시킬 수 있음을 보여준 충격적인 사례입니다.

3.2 독스웨어/유출웨어 (Doxware/Leakware):

파일을 암호화함과 동시에 내부 정보를 탈취하여, 몸값을 지불하지 않으면 데이터를 외부에 공개하겠다고 이종으로 협박하는 방식입니다.

3.2.1 2020년 클롭(Clop) 랜섬웨어의 이랜드 그룹 공격

국내 기업인 이랜드 그룹은 클롭 랜섬웨어 조직의 공격을 받아 **NC백화점**, **김스클럽** 등 오프라인 매장 **50여** 곳 중 **23곳**의 운영을 중단해야 했습니다. 공격 조직은 단순히 시스템을 마비시키는 것을 넘어, 탈취한 고객 카드 정보 등 민감 데이터 **10만** 건을 다크웹에 공개하며 몸값 지불을 압박했습니다. 이는 기업에 막대한 금전적 손실과 함께 돌이킬 수 없는 신뢰도 하락을 야기하는 독스웨어의 위험성을 명확히 보여줍니다.

**** 관련 기사:** <https://www.boannnews.com/media/view.asp?idx=93129>

4. 랜섬 웨어 동작 방식 (공격 사례 기반 분석)

1. **침투 및 감염:** 체인지 헬스케어 사례의 경우, 공격의 시작은 매우 단순했습니다. 해커들은 다중 인증(MFA)이 설정되지 않은 외부 원격 접속용 계정 하나의 자격 증명(ID/비밀번호)을 훔쳐 내부 시스템에 손쉽게 침투했습니다. 이처럼 허술한 계정 관리, 소프트웨어의 보안 취약점, 악성코드가 담긴 이메일 첨부파일 등이 주요 침투 경로가 됩니다.
2. **파일 암호화 및 시스템 장악:** 시스템에 침투한 랜섬웨어는 네트워크로 연결된 모든 저장 장치를 스캔하여 중요 문서, 데이터베이스, 이미지 파일 등을 강력한 알고리즘으로 암호화합니다. 이랜드 그룹 공격 시, 랜섬웨어는 판매 시점 정보 관리 시스템(POS)까지 암호화하여 매장 운영 자체를 불가능하게 만들었습니다.
3. **몸값 요구 및 협박:** 암호화가 완료되면, 공격자는 바탕화면에 랜섬노트(Ransom Note)를 남깁니다. 체인지 헬스케어를 공격한 블랙캣 조직은 시스템 암호화와 더불어 6TB의 데이터를 훔쳤다고 주장하며, 몸값을 지불하지 않으면 민감한 환자 정보를 전부 공개하겠다고 협박하여 압박의 강도를 극대화했습니다.

5. 대응 방안 (현재)

1. 예방 (Prevention)

- 정기적인 데이터 백업: 중요 데이터는 네트워크에서 분리된 오프라인 공간에 보관하는 '3-2-1 백업 규칙'이 필수적입니다.
- 사용자 계정 및 접근 관리 강화: 모든 원격 접속 및 중요 시스템 계정에는 반드시 MFA(다중 인증)를 적용하고, 강력한 비밀번호 정책을 시행하며, 사용하지 않는 계정은 즉시 삭제하여 공격의 접점을 최소화해야 합니다.
- 보안 패치 및 소프트웨어 최신화: 백신, 운영체제, 사용 중인 모든 소프트웨어를 항상 최신 상태로 유지해야 합니다.
- 임직원 보안 교육: 출처가 불분명한 메일과 첨부파일에 대한 경각심을 높이는 주기적인 교육이 반드시 필요합니다.

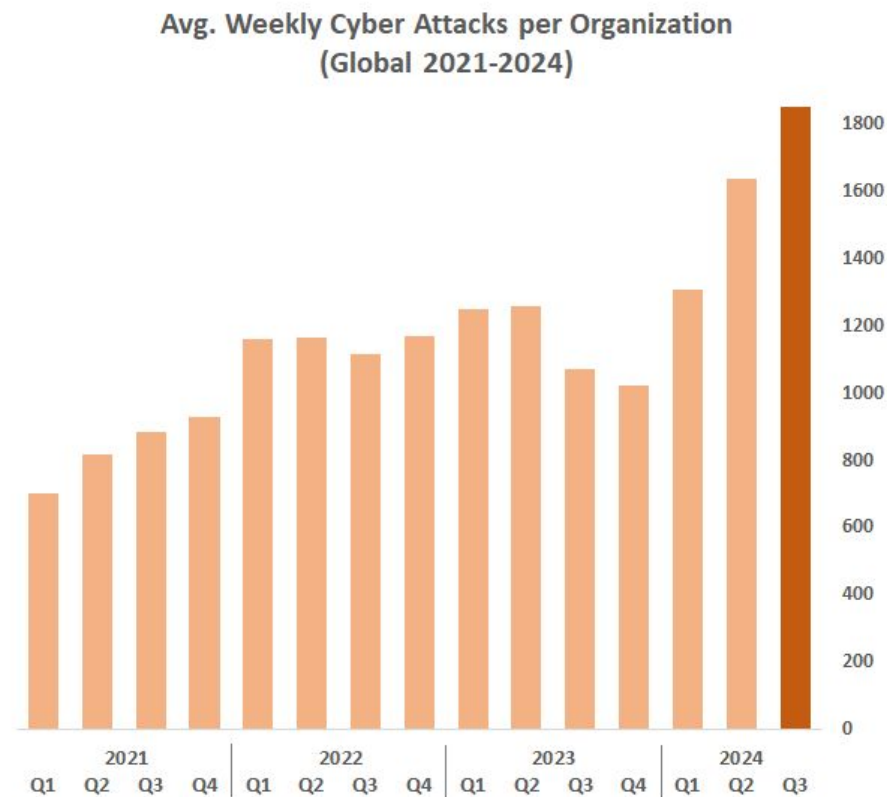
2. 탐지 및 차단 (Detection & Blocking)

- 네트워크 모니터링 및 EDR 솔루션 도입: 알려지지 않은 위협이 내부망에서 확산되는 것을 조기에 탐지하고 차단하는 시스템은 필수적입니다. 엔드포인트(PC, 서버 등)의 이상 행위를 실시간으로 감시하고 대응하는 EDR(엔드포인트 탐지 및 대응, Endpoint Detection and Response) 솔루션이 효과적입니다.

3. 감염 시 대응 및 복구 (Response & Recovery)

- 네트워크 즉시 분리: 감염이 확인되면 즉시 해당 기기의 랜선을 뽑고 와이파이를 꺼서 랜섬웨어가 다른 컴퓨터로 퍼져나가는 것을 막는 것이 최우선입니다.
- 몸값 지불 절대 금지: 몸값을 지불해도 데이터를 온전히 복구한다는 보장이 없으며, 오히려 추가 공격의 대상이 될 수 있습니다.
- 전문기관 신고 및 협력: 한국인터넷진흥원(KISA) 보호나라 등 전문기관에 즉시 신고하여 기술 지원을 받고, 복호화 툴이 있는지 확인해야 합니다.

6. 통계 (Cyber Attack 발생 추이)



The Cost Of Ransomware Is Increasing YoY



7. 통계 (2025년도 통계)

1. 전 세계 사이버 공격 현황 (2025년 11월)

- 전체 공격 규모: 전 세계 조직당 주간 평균 **2,003회**의 사이버 공격이 발생했습니다.
- 증가 추세: 이는 전월(10월) 대비 **3%**, 전년 동월(2024년 11월) 대비 **4%** 증가한 수치입니다.

2. 주요 공격 동향 및 원인

1) 랜섬웨어(Ransomware)의 재급증

- 공격 건수: 11월 한 달간 **727건**의 랜섬웨어 공격이 보고되었으며, 이는 전년 동기 대비 **22%** 급증한 수치입니다.
- 주요 타겟:
 - 국가: 미국(**52%**)이 압도적인 1위 피해국이며, 영국(**4%**), 캐나다(**3%**)가 뒤를 이었습니다.
 - 산업: 제조업(**12%**)이 가장 큰 피해를 입었으며, 비즈니스 서비스(**11%**)와 소비재(**10%**) 분야가 그 뒤를 이었습니다. 이는 해커들이 가동 중단 시 피해가 큰 산업을 노리고 있음을 보여줍니다.

2) 생성형 AI(GenAI) 보안 리스크 심화

- LLM(Large Language Model) 취약성
데이터 오염 공격자는 훈련 단계 동안 의도적으로 변경된 데이터를 LLM에 제공할 수 있습니다. 따라서 모델은 데이터 내부에 숨겨진 백도어를 통해 공격을 받는 취약성을 가질 수 있습니다. 실제 사례로 스팸 이메일을 학습하여 스팸 필터를 공격하고 악용하는 경우가 있습니다.
- 데이터 오염
공격자는 훈련 단계 동안 의도적으로 변경된 데이터를 LLM에 제공할 수 있습니다. 따라서 모델은 데이터 내부에 숨겨진 백도어를 통해 공격을 받는 취약성을 가질 수 있습니다. 실제 사례로 스팸 이메일을 학습하여 스팸 필터를 공격하고 악용하는 경우가 있습니다.